



Risk Treatment Plan (RTP) — Aetheris Therapeutics S.p.A.

Piano Ufficiale di Trattamento dei Rischi (ISO/IEC 27001:2022 Clausola 6.1.3)

Standard di Riferimento: ISO/IEC 27001:2022 (Clausola 6.1.3) & ISO/IEC 27005:2022

Organizzazione: Aetheris Therapeutics S.p.A.

Rif. Documento: RSK-RTP-2026-03

Versione: 1.0

Stato: Approvato

Classificazione: Riservato / Per Uso d'Audit

Data di Efficacia: Agosto 2026

1. Finalità e Governance

Il presente **Risk Treatment Plan (RTP)** formalizza la strategia e le azioni correttive definite da **Aetheris Therapeutics S.p.A.** per mitigare i rischi d'impresa classificati come *Inaccettabili* o *Critici* nel *Risk Register* (RSK-REG-2026-02).

In conformità alla **Clausola 6.1.3 della ISO/IEC 27001:2022**, il piano associa a ciascun rischio:

- * La misura di trattamento prescelta (*Mitigate, Avoid, Transfer, Accept*).
- * I controlli dell'**Annex A (ISO 27001:2022)** e del **NIST CSF v1.1** da implementare.
- * Le risorse economiche (Capex/Opex), i ruoli responsabili (*Owner*) e le scadenze binding.
- * I criteri di re-audit per la verifica della riduzione del rischio al livello residuale target.

2. Sintesi degli Interventi di Trattamento

ID Piano	Rischio Associato	Azione Correttiva Principale	Priorità	Budget Stimato	Scadenza Target
RTP-01	RISK-01 (VPN No MFA)	Implementazione Azure AD MFA & Conditional Access	● CRITICA	€ 3.000 (Opex)	30 Giorni
RTP-02	RISK-02 (Admin Condivisi)	Dismissione account condivisi & Adozione PAM	● CRITICA	€ 15.000 (Capex)	45 Giorni
RTP-03	RISK-03 (Fuga Dati PII)	Mappatura Art. 30 GDPR & Microsoft Purview DLP	● ALTA	€ 8.000 (Opex)	60 Giorni
RTP-04	RISK-04 (Assenza SIEM)	Adozione SIEM Microsoft Sentinel & SOC gestito	● ALTA	€ 25.000 / anno	90 Giorni
RTP-05	RISK-05 (Assenza IRP)	Sviluppo Incident Response Plan & Tabletop Test	● ALTA	€ 5.000 (Consulenza)	60 Giorni
RTP-06	RISK-06 (ITAM Manuale)	Deploy sistema di IT Asset Discovery automatizzata	● MEDIA	€ 6.000 / anno	90 Giorni
RTP-07	RISK-07 (Supply Chain)	Definizione Supplier Security Policy & Security Annex	● MEDIA	In-house Legal	120 Giorni

3. Schede Dettagliate delle Azioni di Trattamento

-  **RTP-01: Implementazione MFA ed Enforce su Connessioni Remoti VPN**
- **Rischio Trattato:** RISK-01 (Rischio Inerente: 20 - CRITICO)
 - **Opzione di Trattamento:** Mitigazione (Mitigate)
 - **Controlli ISO 27001 / NIST:** Annex A.5.15, Annex A.8.5 | NIST PR.AC-3
 - **Descrizione Operativa:** Configurazione dell'integrazione tra il gateway VPN Palo Alto e Microsoft Azure Active Directory tramite protocollo SAML 2.0. Attivazione delle policy di Conditional Access che impongono l'autenticazione a più fattori (Microsoft Authenticator App) per tutti gli accessi remoti.
 - **Owner Responsabile:** Senior Systems Administrator
 - **Budget & Risorse:** € 3.000 (upgrade licenze Microsoft 365 E3/E5)
 - **Target Completion:** 30 Giorni
 - **Criteri di Re-Audit:** Verificare che il 100% dei tentativi di accesso VPN richieda il push MFA e che le connessioni prive di secondo fattore vengano bloccate automaticamente.

-  **RTP-02: Eliminazione Account Amministrativi Condivisi e Introduzione di PAM**
- **Rischio Trattato:** RISK-02 (Rischio Inerente: 20 - CRITICO)
 - **Opzione di Trattamento:** Mitigazione (Mitigate)
 - **Controlli ISO 27001 / NIST:** Annex A.5.18, Annex A.8.2 | NIST PR.AC-4
 - **Descrizione Operativa:** Disattivazione immediata delle credenziali `Domain Admin` generiche e condivise. Creazione di account amministrativi nominali separati dalle utenze standard (`admin.nome.cognome`). Adozione di una soluzione Privileged Access Management (PAM - es. CyberArk o Microsoft PIM) per la gestione e la rotazione automatica delle password di vault/root.
 - **Owner Responsabile:** IT Director
 - **Budget & Risorse:** € 15.000 (Licenze PAM + setup)
 - **Target Completion:** 45 Giorni
 - **Criteri di Re-Audit:** Verificare su Active Directory l'assenza di account generici con privilegi elevati e ispezionare gli audit log della soluzione PAM.

-  **RTP-03: Mappatura Dati PII (Art. 30 GDPR) e Attivazione Controlli DLP**
- **Rischio Trattato:** RISK-03 (Rischio Inerente: 16 - ALTO)
 - **Opzione di Trattamento:** Mitigazione (Mitigate)
 - **Controlli ISO 27001 / NIST:** Annex A.5.34, Annex A.8.12 | NIST ID.GV-3, PR.DS-4
 - **Descrizione Operativa:** Mappatura integrale dei trattamenti dei dati personali e sensibili dei pazienti trattati nei laboratori R&D. Formalizzazione del Registro ex Art. 30 GDPR. Configurazione delle regole di Data Loss Prevention (DLP) su Microsoft Purview per inibire il trasferimento non autorizzato di file riservati o PII via email, USB o cloud storage non aziendali.
 - **Owner Responsabile:** Legal & Compliance Lead (in collaborazione con IT Director)
 - **Budget & Risorse:** € 8.000 (Consulenza Privacy & configurazione Purview)
 - **Target Completion:** 60 Giorni
 - **Criteri di Re-Audit:** Esame del Registro Art. 30 e verifica tecnica blocco DLP su invio email contenenti dati PII verso domini esterni.



RTP-04: Centralizzazione Log e Attivazione Servizio SIEM/SOC Managed h24

- **Rischio Trattato:** RISK-04 (Rischio Inerente: 16 - ALTO)
- **Opzione di Trattamento:** Mitigazione & Trasferimento (Mitigate / Transfer)
- **Controlli ISO 27001 / NIST:** Annex A.8.15, Annex A.8.16 | NIST DE.AE-3, DE.CM-1
- **Descrizione Operativa:** Redirezione dell'invio dei log di audit prodotte da Firewall Palo Alto, Active Directory, Azure AD e server R&D verso una piattaforma SIEM (Microsoft Sentinel). Ingaggio di un Security Operations Center (SOC) gestito h24 in outsourcing (MSSP) per il monitoraggio, la correlazione degli eventi e la notifica proattiva di minacce.
- **Owner Responsabile:** Cybersecurity Analyst
- **Budget & Risorse:** € 25.000 / anno (Infrastruttura Cloud Sentinel + Servizio MSSP)
- **Target Completion:** 90 Giorni
- **Criteri di Re-Audit:** Verifica della dashboard SIEM, controllo della ricezione log e simulazione di un evento di sicurezza con notifica generata dal SOC entro 15 minuti.



RTP-05: Redazione Incident Response Plan e Test di Simulazione Tabletop

- **Rischio Trattato:** RISK-05 (Rischio Inerente: 12 - ALTO)
- **Opzione di Trattamento:** Mitigazione (Mitigate)
- **Controlli ISO 27001 / NIST:** Clausola 5.24, Annex A.5.26 | NIST RS.RP-1
- **Descrizione Operativa:** Sviluppo del documento formale di *Incident Response Plan* conforme alle linee guida NIST SP 800-61 Rev. 2. Definizione dei ruoli della Computer Incident Response Team (CIRT), delle matrici di escalation interna ed esterna (Garante Privacy, CSIRT Italia) e conduzione di un esercizio di simulazione (Tabletop Exercise) con la partecipazione della Direzione aziendale.
- **Owner Responsabile:** Cybersecurity Analyst (in collaborazione con Lead Auditor)
- **Budget & Risorse:** € 5.000 (Consulenza specialistica)
- **Target Completion:** 60 Giorni
- **Criteri di Re-Audit:** Verificare la presenza del documento approvato, il verbale del Tabletop test e il tracciamento dei contatti d'emergenza.



RTP-06: Automatizzazione dell'Inventario IT Management (ITAM)

- **Rischio Trattato:** RISK-06 (Rischio Inerente: 9 - MEDIO)
- **Opzione di Trattamento:** Mitigazione (Mitigate)
- **Controlli ISO 27001 / NIST:** Annex A.5.9 | NIST ID.AM-1, ID.AM-2
- **Descrizione Operativa:** Implementazione e deployment di un software dedicato per l'IT Asset Management con agent automatici installati sugli endpoint e scanner di rete agentless. Dismissione definitiva del registro asset gestito su foglio di calcolo Excel.
- **Owner Responsabile:** IT Director
- **Budget & Risorse:** € 6.000 / anno (Licenze SaaS ITAM)
- **Target Completion:** 90 Giorni
- **Criteri di Re-Audit:** Verificare che l'inventario si aggiorni automaticamente in tempo reale e confrontare le macchine attive in AD con quelle censite nello strumento.



RTP-07: Definizione Supplier Security Policy e Security Annex Contrattuali

- **Rischio Trattato:** RISK-07 (Rischio Inerente: 9 - MEDIO)
- **Opzione di Trattamento:** Mitigazione (Mitigate)

- **Controlli ISO 27001 / NIST:** Annex A.5.19 | NIST ID.SC-3
- **Descrizione Operativa:** Creazione di una procedura di Supplier Risk Management. Integrazione di un *Security Annex* standard nei contratti con i fornitori SaaS/IT che imponga la notifica dei data breach entro 24 ore, il rispetto della certificazione ISO 27001 o SOC 2 e il diritto d'audit per Aetheris S.p.A.
- **Owner Responsabile:** Legal & Compliance Lead
- **Budget & Risorse:** Risorse interne (In-house Legal)
- **Target Completion:** 120 Giorni
- **Criteri di Re-Audit:** Verificare il campionamento sugli ultimi 5 contratti stipulati con fornitori SaaS e verificare la presenza del Security Annex firmato.

4. Sintesi del Budget e Proiezione Finanziaria della Remediation

Tipologia di Costo	Dettaglio Voci di Spesa	Importo Stimato
Spese d'Investimento (Capex)	Soluzione PAM, Licenze e setup iniziale	€ 15.000
Spese Operative Annuali (Opex)	Licenze Azure MFA, SIEM Sentinel, SOC h24 MSSP, ITAM SaaS	€ 42.000 / anno
Consulenza Specialistica	Policy Privacy, Incident Response Plan, Tabletop Test	€ 13.000
TOTALE BUDGET REMEDIATION	Investimento complessivo Anno 1 per la conformità SGSI	€ 70.000

5. Controllo Documentale e Approvazione (ISO 27001:2022 Clausola 7.5)

Ruolo	Nome e Cognome	Stato	Data
Redatto da (Lead Auditor)	Emanuele Tarchi	Completato	Agosto 2026
Revisionato da (IT Director)	IT Director ad interim	Revisionato	Agosto 2026
Approvato da (Alta Direzione)	Chief Executive Officer (CEO)	Approvato	Agosto 2026